NORTHGATE SIGNAL, INC. — KSI VALIDATION REGISTER (SECURITY DECISION RECORD)

Caseline Platform | FedRAMP 20x Class C | Consolidated Rules for 2026 | Generated from ksi_validator.py — this sheet is a rendering of machine-readable evidence, not hand-authored | Sample portfolio artifact, fictional company

KSI ID	KSI Family	KSI Name	KSI Statement	Related SP 800-53 Controls	Validation Method 1 (Control Plane)	Method 1 Result	Validation Method 2 (Observed)	Method 2 Result	KSI Status	Drift Detected	Key Metrics
KSI-IAM-AAM	Identity and Access Management	Automating Account Management	The lifecycle and privileges of all accounts, roles, and groups are securely managed using automation.	AC-02(02), AC-02(03), AC-02(13), AC-06(07), IA-04(04), IA-12, IA-12(02), IA-12(03), IA-12(05)	IdP and cloud IAM inventory query	PASS	Automated access review job output	PASS	TRUE	No	accounts_total=412; automated_lifecycle_pct=100.0; manually_provisioned=0; days_since_review=2; review_interval_days=7; flagged=3; remediated=3; open_findings=0
KSI-IAM-APM	Identity and Access Management	Adopting Passwordless Methods	Secure passwordless methods are used for user authentication and authorization when feasible, otherwise strong passwords with phishing-resistant MFA is used.	AC-03, IA-02, IA-02(01), IA-02(02), IA-02(08), IA-05, IA-05(01), IA-05(02), IA-05(06), IA-06	IdP authentication policy read	PASS	Authentication event log analysis	PASS	TRUE	No	phishing_resistant_required=True; passwordless_enabled=True; password_fallback_allowed=False; authentications_30d=48213; phishing_resistant_mfa_pct=100.0; passwordless_pct=93.55
KSI-IAM-ELP	Identity and Access Management	Ensuring Least Privilege	Identity and access management measures are used and persistently reviewed to ensure each user or device can only access the resources they need.	AC-02(05), AC-02(06), AC-03, AC-04, AC-06, AC-12, AC-17, AC-20, IA-02, IA-03	Role binding enumeration	PASS	Persistent least-privilege review closure	PASS	TRUE	No	standing_privileged_roles=0; jit_eligible_roles=14; flagged=3; remediated=3
KSI-IAM-JIT	Identity and Access Management	Authorizing Just-in-Time	A least-privileged, role and attribute-based, and just-in-time security authorization model is used and persistently reviewed for all user and non-user accounts and services.	AC-02, AC-02(01), AC-05, AC-06, AC-06(01), AC-06(02), AC-06(05), AC-06(09), AC-06(10), CM-05	JIT workflow configuration check	PASS	Privilege elevation event telemetry	PASS	TRUE	No	jit_eligible_roles=14; max_session_minutes=60; elevations_30d=331; via_jit=331; bypassed_jit=0; median_duration_minutes=22; exceeded_max_duration=0
KSI-IAM-SNU	Identity and Access Management	Securing Non-User Authentication	Appropriately secure authentication methods are used and persistently reviewed for non-user accounts and services.	AC-02, AC-02(02), AC-04, AC-06(05), IA-03, IA-05(02), RA-05(05)	Non-user principal inventory	PASS	Repository and image secret scanning	PASS	TRUE	No	non_user_accounts=63; workload_identity=63; static_credentials=0; repos_scanned=34; static_credentials_detected=0; scan_frequency=per-commit
KSI-IAM-SUS	Identity and Access Management	Responding to Suspicious Activity	Accounts with privileged access are disabled or otherwise secured in response to suspicious activity.	AC-02, AC-02(01), AC-02(03), AC-02(13), AC-07, PS-04, PS-08	Automated risk-response policy check	PASS	Risk signal response telemetry	PASS	TRUE	No	auto_disable_enabled=True; risk_signals_30d=9; auto_disabled=9; median_response_seconds=4; manual_interventions=0
KSI-CMT-LMC	Change Management	Logging Changes	System modifications are logged and monitored.	CM-03, CM-05, AU-02, AU-06, AU-09	Change logging configuration verification	PASS	Change event to approval reconciliation	PASS	TRUE	No	forwarding_enabled=True; immutable_storage=True; change_events_30d=1904; reconciled_to_tickets=1904; unreconciled=0
KSI-CMT-IMM	Change Management	Deploying Immutable Resources	Changes are executed through redeployment of version controlled immutable resources rather than direct modification wherever possible.	CM-02, CM-03, CM-04, CM-08, SA-11	Deployment source verification	PASS	CI/CD gate execution records	PASS	TRUE	No	deployments_30d=214; from_version_control=214; manual_or_console=0; with_test_gate=214; with_peer_review=214; emergency_changes=3; emergency_with_retrospective=3
KSI-CNA-RNT	Cloud Native Architecture	Restricting Network Traffic	All information resources are configured to limit inbound and outbound traffic.	AC-04, SC-07, SC-07(05), CA-09, CM-07	Declared network policy evaluation	PASS	Observed network flow log analysis	FAIL	FALSE	YES	default_deny_ingress=True; default_deny_egress=True; segments=7; workload_policy_coverage_pct=100.0; flows_observed_30d=18400291; denied=24117; unexpected_permitted=1317; unexpected_flow_source=legacy-reporting-subnet -> analytics-egress
KSI-SVC-SIN	Service Configuration	Securing Information	Federal and sensitive information is encrypted at rest and in transit using validated cryptographic methods.	SC-08, SC-08(01), SC-12, SC-13, SC-28, SC-28(01)	Storage and key management configuration read	PASS	Active protocol negotiation and object scanning	FAIL	FALSE	YES	data_stores=19; encrypted_at_rest=19; cmk_managed=19; keys_past_rotation=0; tls_minimum=1.3; fips_validated=True; endpoints_scanned=41; tls_compliant_endpoints=40
KSI-CED-RAT	Cybersecurity Education	Reviewing All Training	All employees receive security awareness training, and role-specific training is required for high risk roles including those with privileged access.	AT-02, AT-03, AT-04, PS-07	LMS completion record query	PASS	Phishing simulation outcome analysis	PASS	TRUE	No	workforce=88; awareness_completed=88; privileged_role_holders=21; role_specific_completed=21; past_due=0; campaigns_12mo=4; median_click_rate_pct=2.1; target_click_rate_pct=5.0
KSI-INR-RIR	Incident Response	Reviewing Incident Response Procedures	Incident response procedures are documented, regularly reviewed and exercised, and incidents are reported according to FedRAMP requirements.	IR-03, IR-04, IR-05, IR-06, IR-08	IR plan and roster currency check	PASS	Incident record and reporting latency analysis	PASS	TRUE	No	plan_age_days=41; plan_interval_days=180; roster_age_days=26; roster_interval_days=90; roster_unverified=0; exercises_12mo=2; incidents_12mo=4; with_after_action_report=4

DRIFT FINDINGS — CONFIGURATION vs. OBSERVED BEHAVIOR

Each finding below passed control-plane validation and failed observed-behavior validation. A single-method validator would have reported these KSIs as true.

Finding ID	KSI	What the configuration says	What the system actually does	Why it matters	Authoritative signal	Remediation	Target Date	Owner
DRIFT-001	KSI-CNA-RNT	Network policy declares default-deny on both ingress and egress, with explicit policy attached to all 143 workloads (100% coverage).	Flow logs show 1,317 permitted flows over 30 days that match no explicit allow policy, originating from legacy-reporting-subnet toward analytics-egress.	Traffic is traversing a path the declared architecture does not describe. Either an implicit allow exists that policy review cannot see, or the policy engine is not evaluating that subnet. Both are boundary integrity problems.	Observed flow logs	Trace the 1,317 flows to their originating rule; if an implicit allow exists, replace with explicit policy. Add a continuous reconciliation job comparing observed flows to declared policy, alerting on any unmatched permit.	2026-09-15	Cloud Network Engineering
DRIFT-002	KSI-SVC-SIN	Encryption configuration declares TLS 1.3 minimum across all endpoints, FIPS-validated modules, 19/19 data stores encrypted at rest with customer-managed keys.	Active protocol negotiation testing found 1 of 41 endpoints (lb-legacy-reporting-01:443) still accepts TLS 1.0 connections.	The at-rest and key management posture is genuinely strong, but one listener accepts a deprecated protocol. Configuration review alone reports this KSI as satisfied because the declared minimum is correct — the listener override is invisible at that layer.	Active protocol negotiation test	Remove the TLS 1.0 listener policy from lb-legacy-reporting-01. Add protocol negotiation testing to the pre-deployment gate so a listener cannot ship with a policy weaker than the declared minimum.	2026-08-29	Platform Engineering

FEDRAMP 20x CERTIFICATION CLASS REQUIREMENTS

Per CR26 rules FRC-CSX-VVK (automated validation) and FRC-CSX-MOT (metrics over time). Verify current text at fedramp.gov/2026 — these rules are new and evolving.

Requirement	Class A	Class B	Class C (this package)	Class D
Automated validation methods per KSI (FRC-CSX-VVK)	MAY implement	SHOULD implement, at least 1 per KSI	MUST implement, at least 2 per KSI	MUST implement, at least 4 per KSI
Historical KSI metrics (FRC-CSX-MOT)	MAY supply	SHOULD supply	MUST supply, at least past 6 months	MUST supply, at least past 18 months
Fresh independent assessment (FRC-APP-FIA)	MAY supply, within previous 3 months	MUST supply, within previous 3 months	MUST supply, within previous 3 months	MUST supply, within previous 3 months
Prior alternative framework certification (FRC-CLA-ASF)	MUST have Rev5 / SOC 2 Type II / GovRAMP within 12 months	Not applicable	Not applicable	Not applicable
This package's status	—	—	12 KSIs x 2 methods = 24 automated methods; minimum met	—

VALIDATION METHODOLOGY

What this document is	Under FedRAMP 20x, the Security Decision Record replaces the narrative control descriptions of a Rev5 SSP. Rather than describing how a control is implemented, it records what was validated, by what method, with what result, and what the metrics were.
Why two methods	CR26 rule FRC-CSX-VVK requires Class C providers to implement at least two automated validation methods per KSI. The purpose is corroboration from independent sources. Two methods reading the same API is the same assertion counted twice, not two methods.
The pairing used here	Every KSI pairs a CONTROL-PLANE method (what the configuration declares) with a DATA-PLANE or TELEMETRY method (what the running system actually did). Where they disagree, the KSI reports false and the observed behavior is treated as authoritative.
Why that matters	Two of the twelve KSIs in this package fail precisely because the methods disagree. Both would have reported true under configuration review alone. This is the specific failure mode continuous validation exists to catch, and the reason FedRAMP moved away from point-in-time document assessment.
Evidence integrity	Each emitted JSON artifact is SHA-256 hashed into an integrity manifest so that evidence tampering between generation and submission is detectable.
Generation	All values in this workbook are rendered from security-decision-record.json, which is produced by ksi_validator.py. Nothing here is hand-typed. If the underlying system state changes, this register is regenerated rather than edited.
Honest scope note	This is a portfolio artifact for a fictional company. The JSON structure is modeled on CR26 rule requirements and is NOT claimed to validate against FedRAMP's official published JSON schemas at fedramp.gov/schemas, which are authoritative. KSI identifiers and statements are drawn from the Consolidated Rules for 2026 and should be verified against the current published text.